

imperva

API Security Token & Authentication Risk Report

Executive Summary

Over the past year, Thales Imperva API Security tracked authentication and token-handling risk across 1,104 customer accounts and 32,725 API endpoints, comparing what we saw in 2025 to what we're seeing now in 2026. This report walks through what changed, what didn't, and — more importantly — what that tells us about how well organizations are closing their authentication gaps.

The short version: it's a mixed bag. Three of the five risks we track got better this year. Weak signing algorithms, legacy Basic Authentication, and long-lived tokens are all less common than they were in 2025 — real evidence that teams are acting on solid advice like using stronger algorithms, moving to OAuth2/mTLS, and shortening token lifetimes.

The other two risks are the ones that should worry you more, because they're the ones most likely to cause real damage if a token leaks. Sensitive data packed into token payloads now shows up in nearly half of all detections — up from 46.0% to 49.8% — and it's still the single biggest risk category by a wide margin. Expired tokens that keep working long after they should have stopped grew from 5.0% to 8.5% of detections. That's a 70% jump, the sharpest move of anything we measured, in either direction.

And here's a finding that might matter more than any single risk category: **13,016 of the 32,725 endpoints we analyzed — nearly 40% — carry more than one authentication risk at the same time.** This isn't a handful of unlucky outliers. It's roughly **2 out of every 5 endpoints.** The worst single endpoint we found had all five risk types at once. These risks don't usually show up alone — and that looks less like “a few mistakes here and there” and more like a real gap in how authentication is designed and checked, which changes how you should think about fixing it.

This report builds on Imperva's 2025 Authentication Risk Report, which first flagged these five risk categories and laid out fixes for each one. From here, we'll go category by category through what changed between 2025 and 2026, then wrap up with where we think security and engineering teams should focus next.



1,104
ACCOUNTS
ANALYZED

32,725
ENDPOINTS
ANALYZED



5 RISK
CATEGORIES



12 MONTHS
COMPARED

About This Report

This report is built on authentication and token-handling data that Imperva API Security observed across 1,104 customer accounts and 32,725 API endpoints — comparing what we saw in 2025 to what we saw in 2026. We tracked the same five risk categories in both years:

- **SENSITIVE DATA IN JWT**
JSON Web Tokens (JWTs) that contain sensitive data in their payload
- **LONG-LIVED JWTs (HIGH TTL)**
JSON Web Tokens (JWTs) issued with excessively long time-to-live (TTL) values
- **WEAK SIGNING ALGORITHMS**
Tokens signed using weak or insecure signing algorithms
- **BASIC AUTH (RAW CREDENTIALS)**
Endpoints relying on Basic Authentication with raw, unencrypted credentials
- **EXPIRED-TOKEN ACCESS**
Applications or endpoints that remain accessible using tokens after they should have expired

HOW TO READ THESE FIGURES

Each percentage is the share of detections flagged for that one risk — not a slice of a single pie. A single endpoint can easily carry more than one risk at the same time (more on that in “The Bigger Pattern,” later in this report), so these five numbers don’t add up to 100%. They’re not supposed to.

ONE MORE THING WORTH SAYING UPFRONT:

Don’t read every year-over-year change as pure behavior change. A number can move because customers changed something, because our detection got better at spotting it, or because the mix of accounts we measured shifted a bit. Usually, it’s some combination. Where we’re not sure which one is doing the most work, we’ve said so instead of picking the story that sounds best.

The Big Picture: 2025 vs. 2026

Here's the full year-over-year comparison, all five categories side by side.

RISK CATEGORY	2025	2026	Δ (PP)	% CHANGE	TREND
Sensitive Data in JWT	46.0%	49.8%	+3.8 PP	+8.3%	↑ WORSENERD
Long-Lived JWTs (High TTL)	21.0%	19.2%	-1.8 PP	-8.6%	↓ IMPROVED
Weak Signing Algorithms	19.0%	15.2%	-3.8 PP	-20.0%	↓ IMPROVED
Expired-Token Access	5.0%	8.5%	+3.5 PP	+70.0%	↑ WORSENERD
Basic Auth (Raw Credentials)	9.0%	7.3%	-1.7 PP	-18.9%	↓ IMPROVED

RISK PREVALENCE BY CATEGORY: 2025 VS 2026

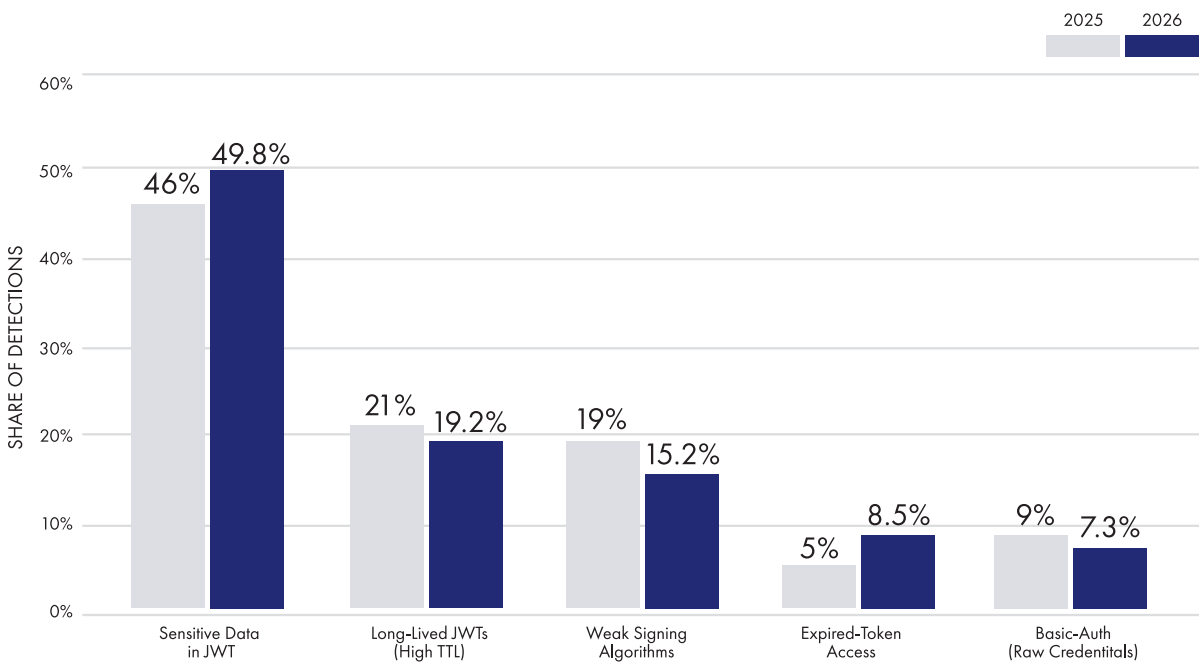


FIGURE 1. Risk prevalence by category, 2025 vs. 2026 — each bar shows the share of endpoints flagged for that risk.

Two things jump out here. First, sensitive data in JWTs isn't just the biggest risk — it's more than five times bigger than the smallest one, in both years. Second, nothing stood still: every category moved by at least 1.7 percentage points, one way or the other. Let's dig into why.

Two Storylines in One Data Set

Averaged together, five categories moving a few points in different directions can look like noise. Split them into what got better and what got worse, though, and a much clearer picture shows up: real progress on the fundamentals, and growing exposure on exactly the risks that matter most if a token ever gets compromised.

WHERE RISK IMPROVED VS. WORSENERD (PERCENTAGE-POINT CHANGE)

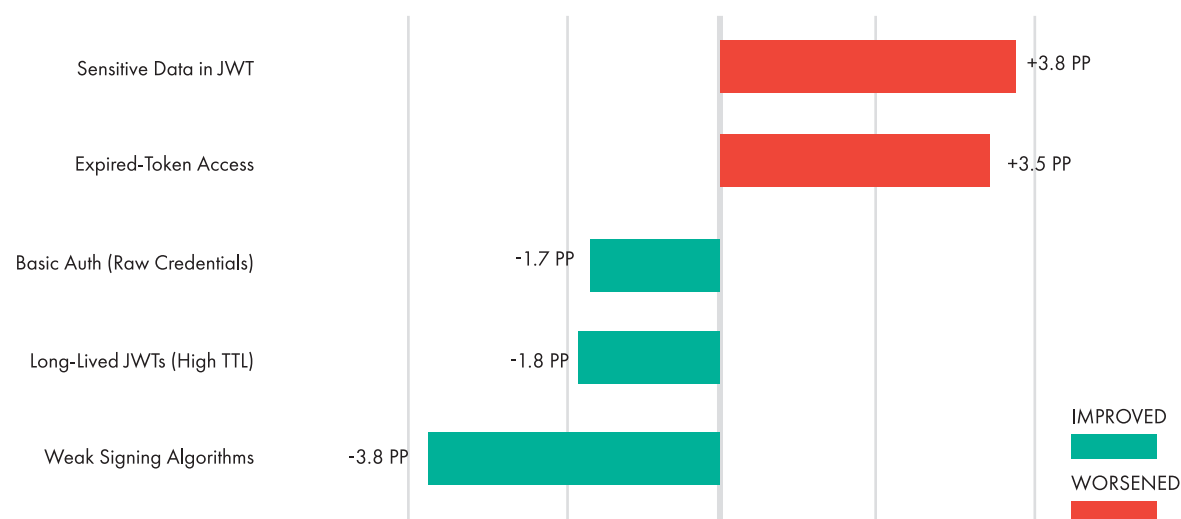


FIGURE 2. Percentage-point change by category, 2025 → 2026. Green = improved, red = worsened.

Where Things Got Better

Three categories got better this year, and they have something in common: each one has a well-known fix that's been standard advice for years.

Weak Signing Algorithms — 19.0% → 15.2%

-3.8 pp • -20.0% relative — the largest relative improvement of any category

This is the biggest relative improvement in the data set. It lines up with what you'd expect if organizations were tightening algorithm enforcement — blocking "none" as an algorithm, retiring weak HMAC setups, and standardizing on algorithms that are considered safe. Some of this drop is probably also because the accounts we measured first, back in 2025, simply had weaker habits than the broader group we're measuring now.

BOTTOM LINE

Algorithm hygiene is heading the right way, but roughly 1 in 7 detections still have a weak signing configuration. Worth confirming this is fixed everywhere, not just assuming it is.

Basic Authentication (Raw Credentials) — 9.0% → 7.3%

–1.7 pp • –18.9% relative

Basic Authentication with raw credentials kept declining, which tracks with the broader shift toward OAuth2 and mutual TLS (mTLS) as the default way to authenticate.

BOTTOM LINE

The move away from Basic Auth is real, and it's worth keeping up. But legacy endpoints tend to hide — go inventory yours rather than assuming they're all gone.

Long-Lived Tokens (High TTL) — 21.0% → 19.2%

–1.8 pp • –8.6% relative

Token lifetimes got a little better, likely thanks to more teams pairing shorter TTLs with refresh tokens.

BOTTOM LINE

This is the smallest win of the three, and long-lived tokens are still the second-biggest risk category overall. Call it progress, not a victory lap — don't deprioritize it just because the line is pointing down.

Where Things Got Worse

The three risks above all have a checklist-style fix: pick the right protocol, roll it out, done. The two below are different. They're less about which protocol you chose and more about getting the details right — and both are heading the wrong way.

Sensitive Data in JWTs — 46.0% → 49.8%

+3.8 pp • +8.3% relative — the largest risk category in both years, and still growing

This is the headline number in this report. Sensitive data baked into token payloads was already the most common risk back in 2025 — a year later, it's even more common, showing up in almost half of everything we detected.

There are a few reasons this could be happening, and they're not mutually exclusive. More teams might genuinely be putting PII and other sensitive fields into tokens. Our detection might have gotten sharper at spotting it. Or the accounts we measured in 2026 just happen to skew toward organizations that do this more. Realistically, it's probably some mix of all three.

BOTTOM LINE

Whichever explanation you buy, the direction is the same either way: this is still risk #1, and it's getting more common, not less. Treat token payload minimization as an ongoing priority, not a one-time cleanup.

Expired-Token Access — 5.0% → 8.5%

+3.5 pp • +70.0% relative — the sharpest move of any category, in either direction

This is the shift that concerns us most, for two reasons. First, token expiration is one of the more mechanical things to get right in an authentication implementation — there's a lot less gray area here than, say, deciding what counts as "sensitive" data. Second, a 70% jump in one year is a big move by any measure.

As with sensitive-data exposure, there are a few possible explanations: a different mix of accounts this year, better detection catching problems that were already there, or a real increase in expired tokens slipping through. We can't say for certain which one is driving it most.

BOTTOM LINE

This one's worth digging into directly rather than taking at face value. Start by auditing server-side exp and nbf claim enforcement and check your cache-invalidation logic — those two are the usual suspects behind tokens that outlive their expiration date.

RELATIVE CHANGE TELLS A SHARPER STORY

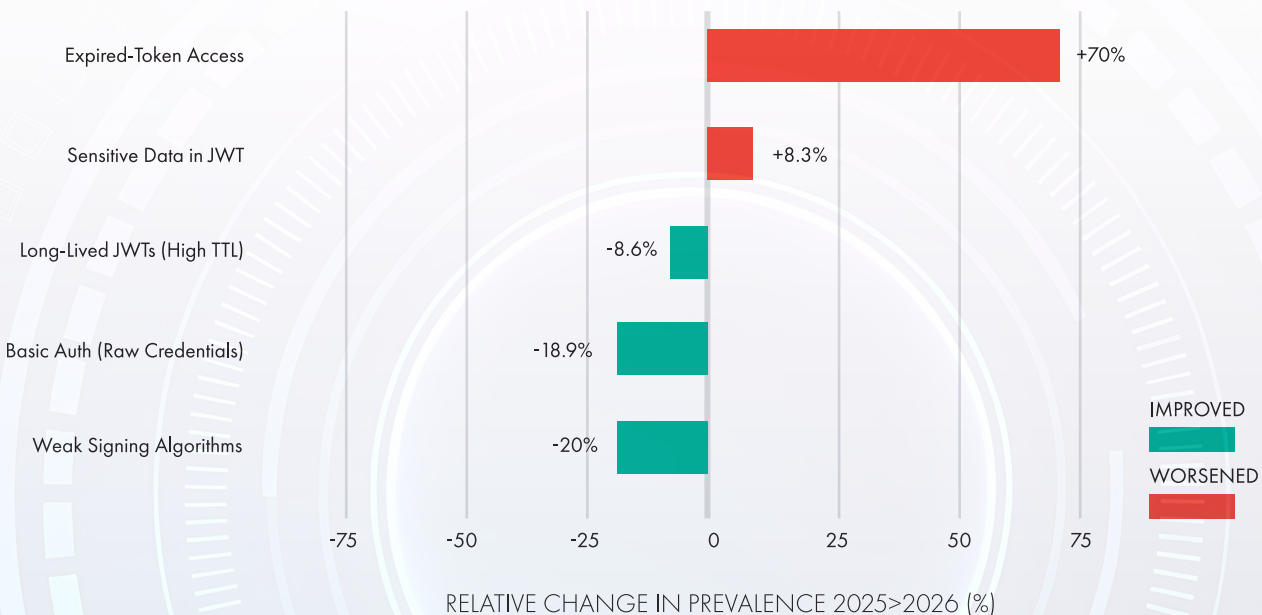


FIGURE 3. Relative change by category, 2025 → 2026. Expired-token access grew faster, in relative terms, than any other risk category measured.

The Bigger Pattern: Why Risks Cluster

Every stat so far in this report describes one risk at a time. That's not how risk actually shows up on a real endpoint — and this is the finding that should change how you prioritize fixing it.

Of the 32,725 endpoints we analyzed, 13,016 — nearly 40% — carry more than one authentication risk at the same time. That's not an edge case worth a footnote. That's roughly 2 out of every 5 endpoints in the entire data set carrying a stacked, compounding risk instead of a single, isolated one.

NEARLY 2 IN 5 ENDPOINTS CARRY MORE THAN ONE RISK

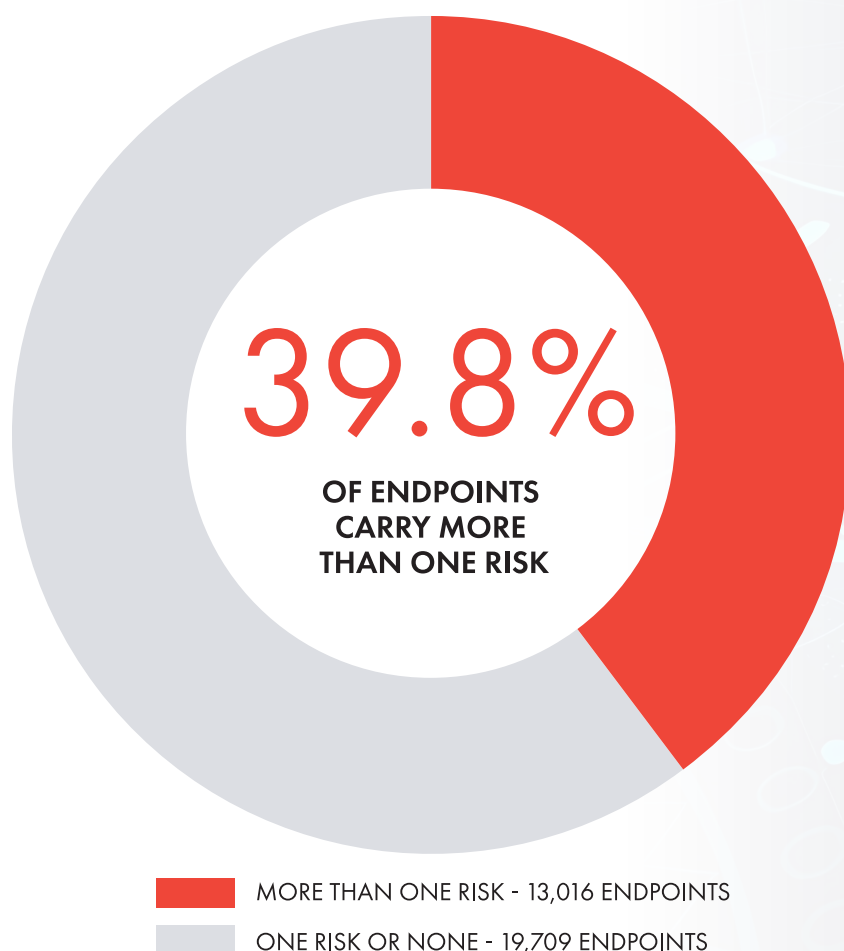


FIGURE 4. Share of endpoints carrying more than one concurrent authentication risk.

Here's why that matters in practice, not just in the aggregate. Picture an endpoint that embeds sensitive data inside its tokens — a risk present in essentially half of all detections — sitting alongside an expired-token gap that lets access continue indefinitely, a risk that grew 70% this year alone. We can't say how often that exact pairing occurs; our data shows endpoints carrying multiple risks, not which specific risks pair together most often. But it's exactly the kind of compounding scenario nearly 40% of endpoints are positioned for — and it's the reason a single "authentication risk" finding deserves more scrutiny than a single-item fix.

And at the extreme end, it gets worse than a pairing. The single riskiest endpoint we found didn't have two risks stacked. It had all five, on one endpoint, at once:

- **Sensitive data embedded in the token**
- **A weak signing algorithm**
- **An excessively long token lifetime (high TTL)**
- **Basic Authentication with raw credentials**
- **Continued access after token expiry**

If these risks were scattered at random, an endpoint like that should be a statistical fluke — the kind of thing you'd expect to find once and never again. Instead, the pattern repeats across nearly 40% of the endpoints we looked at. That's not scattered. That's systemic. An endpoint with one authentication risk is far more likely than chance to have another sitting right next to it — which means the fix most teams reach for first, patching the one risk they found, usually leaves the rest of the problem standing.

BOTTOM LINE

Nearly 40% of endpoints in this data set carry more than one authentication risk at once. If your team finds one, the smart assumption isn't "we caught it" — it's "what else is here."

Key Takeaways

1. Sensitive data in JWTs won't go away on its own.

It's the biggest risk category two years running — roughly half of all detections — and it grew instead of shrinking. For most teams reading this, it should be priority number one.

2. This isn't a handful of anecdotes.

1,104 accounts and 32,725 endpoints is a real sample size, drawn from real customer environments — not a few cherry-picked examples.

3. Progress was real, but it wasn't uniform.

Three categories improved because teams adopted known best practices. Two got worse, and both come down to implementation details rather than which protocol was chosen.

4. Expired-token access is growing faster than anything else we track.

A 70% jump, even from a small base, is the sharpest move in the data set and deserves a closer look.

5. Authentication risks cluster instead of scattering.

13,016 endpoints — nearly 40% of everything we analyzed — carry more than one risk at once, and the worst-case endpoint had all five. That's a sign of gaps in the system, not isolated mistakes.

Where We Recommend You Focus Next

1. **Make token payload minimization an ongoing habit, not a project.**

Go look at what's inside your JWTs. Strip out PII and other sensitive fields you don't strictly need, and lean toward opaque, reference-style tokens when the service on the other end can just look the data up server-side.

2. **Dig into expired-token access specifically.**

Make sure exp and nbf claims are enforced server-side, on every service that validates tokens, not just at the gateway — and check your cache and session-invalidation logic for anything that might keep a token alive longer than it should be.

3. **Keep doing what's already working.**

Finish migrating the remaining Basic Auth endpoints to OAuth2 or mTLS, keep rolling out shorter TTLs with refresh tokens, and make sure strong signing-algorithm enforcement covers legacy and third-party services too — not just the new stuff.

4. **Audit by endpoint, not by risk type.**

Since risks cluster together, an endpoint that fails one check is likely to fail others too. A full authentication review on flagged endpoints will get you further than closing tickets one risk category at a time.

5. **Re-check your own numbers regularly.**

Benchmarks like this one are useful for context, but the comparison that helps you is your own trend over time — measured the same way, on a regular schedule.

See How Your Environment Compares

The numbers in this report come from real-world detection data across Thales Imperva API Security's customer base. They're useful for context, but they're not a substitute for knowing where your own APIs stand today. If you'd like help figuring that out, we'd welcome the conversation.

Reach out to your Thales representative, or visit cpl.thalesgroup.com/contact-us to get a benchmark review of your own environment using Thales Imperva API Security.

Methodology & Notes

- This data comes from Imperva API Security's analysis across 1,104 accounts and 32,725 API endpoints, comparing what was detected in 2025 and 2026.
- The five risk categories aren't mutually exclusive — a single endpoint can be flagged for more than one, which is why the percentages don't add up to 100%. Of the 32,725 endpoints analyzed, 13,016 (39.8%) were flagged for more than one risk type at the same time.
- Year-over-year changes can reflect a mix of things: actual changes in customer behavior, improvements in our own detection, or shifts in which accounts got measured each year. Where more than one explanation seems plausible, we've said so rather than picking just one.

imperva

Contact us

For all office locations and contact information,
please visit cpl.thalesgroup.com/contact-us

thalesgroup.com